

Phụ Lục: Báo Cáo Kiểm Toán AI (AI Audit Report)

Sinh viên thực hiện: Lâm Hữu Khánh

Mã số sinh viên: 23127205

Môn học: Kiểm thử phần mềm (Software Testing) — HW06: Kiểm thử API & Ứng dụng AI

Thời gian thực hiện: 30/08/2026 – 31/08/2026

1. Khai Báo Sử Dụng AI (Mandatory AI Declaration)

"I use AI tools for the following tasks:" 1. Phân tích các yêu cầu SUT (eshop-sut/api_specification.md và eshop-sut/README.md) để sinh test cases API có cấu trúc cho 3 API được chọn: - **Pool A:** FR-02 — Ứng dụng & Khóa tài khoản (POST /api/login) - **Pool B:** FR-07 — Gửi hàng (GET /api/cart, POST /api/cart) - **Pool C:** FR-15 — Quản lý sản phẩm CRUD (POST/GET/PUT/DELETE /api/products) 2. Chuyển đổi tài liệu các tài liệu API sang chuẩn OpenAPI 3.0 (docs/openapi.yaml). 3. Thiết kế các kịch bản kiểm thử JSON Schema Validation (ajv) và Chai Assertions cho Postman Tests. 4. Xây dựng các kiến trúc và mã nguồn trình khai cho Agent Skill (G9.5 Create: AI API Test Generator).

2. Nhật Ký Toàn Bộ Các Phiên Kiểm Toán AI (Detailed AI Audit Logs)

Phiên 1: Sinh Test Cases cho FR-02 — Ứng Dụng & Khóa Tài Khoản (POST /api/login)

- Tên công cụ AI: Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- Ngày và giờ: 2026-08-30 20:15:30 +07:00
- Prompt của bạn: ``text Bạn là một Senior API QA Automation Engineer. Dựa trên tài liệu các tài liệu EShop (SRS & api_specification.md):
 - Endpoint: POST /api/login
 - Body: { "email": "string", "password": "string" }
 - Yêu cầu nghiệp vụ FR-02:
 - Ứng dụng thành công trả về 200 OK kèm JWT token và user object (gồm id, role, email, name).
 - Mỗi lần ứng dụng sai thông tin, bộ đếm login_attempts tăng đúng 1 lần.
 - Nếu ứng dụng sai 3 lần liên tiếp, tài khoản bị tạm khóa 30 giây (trả về 403 Forbidden).

4. Sau khi h■t 30s ho■c ■■ng nh■p ■■ng, b■ ■■■m ■■■c reset v■ 0.

5. B■o m■t: M■t kh■u không l■u plaintext (SEC-01), ch■ng SQL Injection (SEC-05), ch■ng Brute-force.

H■y thi■t k■ 38 Test Cases c■ c■u tr■c b■ng r■ r■ng, ph■n b■ theo 4 k■ thu■t ki■m th■: - Ph■n ho■ch mi■n (Equivalence Partitioning & Boundary Value Analysis) - Chuy■n tr■ng th■i (State Transition Testing cho chu tr■nh khóa tài kho■n) - B■o m■t (Security Testing: SQLi, Brute-force, Tampered Token) - Schema Validation (JSON Schema response 200, 400, 401, 403)

M■i test case ph■i c■: TestID, Coverage Type, Description, Request Body, Expected Status Code, Expected Response.
...

• ■■■u ra c■a AI: ```markdown ### A. Ph■n ho■ch mi■n & Giá tr■ bi■n (Domain Partitioning - 14 TCs) | TestID | Coverage Type | Mô t■ | Request Body | Expected Status | Expected Response Shape |
|---|---|---|---|:---:|---| | TC_FR02_DOM_01 | Domain Valid | ■■ng nh■p tài kho■n user chu■n | {"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"...", "user":{"...}} |
TC_FR02_DOM_02 | Domain Valid | ■■ng nh■p tài kho■n admin chu■n | {"email":"admin@eshop.com","password":"Admin123!"} | 200 | {"message":"Login successful","token":"...", "user":{"role":"admin"}} |
TC_FR02_DOM_03 | Domain Invalid | Email sai ■■nh d■ng (thi■u @) | {"email":"testeshop.com","password":"Test1234!"} | 400 | {"error": string} |
TC_FR02_DOM_04 | Domain Invalid | Email sai ■■nh d■ng (thi■u domain) | {"email":"test@","password":"Test1234!"} | 400 | {"error": string} |
TC_FR02_DOM_05 | Domain Invalid | Email ■■ tr■ng chu■i r■ng | {"email":"","password":"Test1234!"} | 400 | {"error": string} |
TC_FR02_DOM_06 | Domain Invalid | Thi■u h■n tr■ng email trong JSON | {"password":"Test1234!"} | 400 | {"error": string} |
TC_FR02_DOM_07 | Domain Invalid | Password ■■ tr■ng chu■i r■ng | {"email":"test@eshop.com","password":""} | 400 | {"error": string} |
TC_FR02_DOM_08 | Domain Invalid | Thi■u h■n tr■ng password | {"email":"test@eshop.com"} | 400 | {"error": string} |
TC_FR02_DOM_09 | Domain Invalid | C■ email và password ■■u r■ng | {"email":"","password":""} | 400 | {"error": string} |
TC_FR02_DOM_10 | Domain Invalid | Password sai giá tr■ | {"email":"test@eshop.com","password":"WrongPass999!"} | 401 | {"error":"Invalid email or password"} |
TC_FR02_DOM_11 | Domain Invalid | Email không t■n t■i trong h■ th■ng | {"email":"nonexistent@eshop.com","password":"Test1234!"} | 401 | {"error":"Invalid email or password"} |
TC_FR02_DOM_12 | Boundary | Email c■c dài (255 ký t■ h■p l■) | {"email":"a...a@eshop.com","password":"Test1234!"} | 401 | {"error":"Invalid email or password"} |
TC_FR02_DOM_13 | Boundary | Password 7 ký t■ (d■i chu■n 8 ký t■) | {"email":"test@eshop.com","password":"Pass12!"} | 401 | {"error":"Invalid email or password"} |
TC_FR02_DOM_14 | Domain Invalid | Ki■u d■ li■u email là s■ | {"email":12345,"password":"Test1234!"} | 400 | {"error": string} |

B. Chuy■n tr■ng th■i (State Transition - 9 TCs) | TestID | Coverage Type | Mô t■ | Request Body | Expected Status | Expected Response Shape |
|---|---|---|---|:---:|---| | TC_FR02_ST_01 | State Transition | ■■ng nh■p sai l■n 1 (Counter = 1) | {"email":"lockout_target@eshop.com","password":"wrong"} | 401 | {"error":"Invalid email or password"} |
TC_FR02_ST_02 | State Transition | ■■ng nh■p sai l■n 2 (Counter = 2) | {"email":"lockout_target@eshop.com","password":"wrong"} | 401 | {"error":"Invalid email or password"} |
TC_FR02_ST_03 | State Transition | ■■ng nh■p sai l■n 3 -> Chuy■n sang LOCKED (30s) | {"email":"lockout_target@eshop.com","password":"wrong"} | 401 | {"error":"Invalid email or password"} |
TC_FR02_ST_04 | State Transition | ■■ng nh■p khi tài kho■n ■ang b■ khóa (L■n 4) | {"email":"lockout_target@eshop.com","password":"Lockout123!"} | 403 | {"error":"Tài kho■n ■ã b■ khóa. Vui lòng th■ l■i sau."} |
TC_FR02_ST_05 | State Transition | Nh■p sai pass khi tài kho■n ■ang b■ khóa | {"email":"lockout_target@eshop.com","password":"wrong"} | 403 | {"error":"Tài kho■n ■ã b■ khóa. Vui lòng th■ l■i sau."} |
TC_FR02_ST_06 | State Transition | ■■ng nh■p ■■ng sau khi h■t th■i gian khóa 30s |

```

{"email":"logout_target@eshop.com","password":"Logout123!"} | 200 | {"message":"Login
successful","token":"..."} || TC_FR02_ST_07 | State Transition | Reset Counter: Sai 1 l...n r...i nh...p ...úng ngay |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"..."} ||
TC_FR02_ST_08 | State Transition | Khóa tài kho...n không ...nh h...ng ...n user khác |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"..."} ||
TC_FR02_ST_09 | State Transition | ...ng nh...p ...úng liên ti...p không b... khóa |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"..."} |

```

```

### C. B...o m...t (Security Testing - 9 TCs) | TestID | Coverage Type | Mô t... | Request Body | Expected Status |
Expected Response Shape | |---|---|---|---|---|---| | TC_FR02_SEC_01 | SQL Injection | SQLi bypass c... b...n trong email |
{"email":"' OR 1=1 --","password":"any"} | 401 | {"error":"Invalid email or password"} || TC_FR02_SEC_02 |
SQL Injection | SQLi bypass d...ng boolean | {"email":"admin@eshop.com' OR '1'='1","password":"any"} | 401 |
{"error":"Invalid email or password"} | | TC_FR02_SEC_03 | SQL Injection | SQLi trong password |
{"email":"admin@eshop.com","password":"' OR 1=1 --"} | 401 | {"error":"Invalid email or password"} | |
TC_FR02_SEC_04 | XSS | XSS script payload trong email |
{"email":"<script>alert(1)</script>@eshop.com","password":"pass"} | 400 | {"error": string} | |
TC_FR02_SEC_05 | Brute Force | G...i request liên t...c 10 l...n v...i dictionary passwords | L...p l...i POST /api/login | 403
| Tài kho...n ph...i b... khóa t... l...n 3 | | TC_FR02_SEC_06 | Header Injection | Header Content-Type không h...p l...
(text/plain) | Body: plain text | 400 / 415 | Unsupported Media Type | | TC_FR02_SEC_07 | Password Leak | Ki...m tra
response 200 không ch...a password hash/plaintext | {"email":"test@eshop.com","password":"Test1234!"} | 200 |
Response user KHÔNG ch...a tr...ng password | | TC_FR02_SEC_08 | Token Signing | JWT Token tr... v... ph...i có 3
ph...n tách bi...t b...i d...u ch...m | {"email":"test@eshop.com","password":"Test1234!"} | 200 |
token.split('.').length === 3 | | TC_FR02_SEC_09 | Error Message Obfuscation | Sai email ho...c sai pass ...u tr...
v... cùng 1 thông báo chung | {"email":"wrong","password":"wrong"} | 401 | error === "Invalid email or password"
|

```

```

### D. Ki...m tra Schema (Schema Validation - 6 TCs) | TestID | Coverage Type | Mô t... | Request Body | Expected Status
| Expected Schema | |---|---|---|---|---|---| | TC_FR02_SCH_01 | Schema 200 | Validate c...u trúc Response thành công |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | JSON Schema: {message: string, token: string,
user: {id: int, role: string, ...}} | | TC_FR02_SCH_02 | Schema 401 | Validate c...u trúc Response l...i 401 |
{"email":"test@eshop.com","password":"wrong"} | 401 | JSON Schema: {error: string} | | TC_FR02_SCH_03 |
Schema 403 | Validate c...u trúc Response khóa 403 | {"email":"locked@eshop.com","password":"pass"} | 403 | JSON
Schema: {error: string} | | TC_FR02_SCH_04 | Schema Content-Type | Header Content-Type tr... v... ph...i là
application/json | {"email":"test@eshop.com","password":"Test1234!"} | 200 | Content-Type: application/json;
charset=utf-8 | | TC_FR02_SCH_05 | Schema Token Format | Token ph...i là chu...i ...nh d...ng JWT h...p l... |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | Regex:
^[A-Za-z0-9-_=]+\.[A-Za-z0-9-_=]+\.[A-Za-z0-9-_.+/*]*$ | | TC_FR02_SCH_06 | Schema 400 | Validate c...u trúc
Response l...i 400 khi body r...ng | {} | 400 / 401 | JSON Schema: {error: string} | ``

```

- **Ánh giá ki...m toán c...a con ng...i (Human Audit Decision):**

- **Nhãn t...ng h...p:** 26 VALID, 5 INVALID, 7 INCOMPLETE.

Chi ti...t ki...m toán:

- TC_FR02_DOM_03 ~ DOM_06 (INVALID): AI gi...i ...nh backend tr... v... 400 Bad Request khi email sai ...nh d...ng, nh...ng th...c t... server.js truy v...n CSDL tr... v... 401. Chuy...n các test này sang 02_Bug_Discovery_Suite ... b...t bug thi...u validation format c...a SUT.

- TC_FR02_DOM_14 (INVALID): Gọi email đúng số, SQLite ép kiểu thành string. Sửa lại assertion test không bị gây trên SUT.
- TC_FR02_SEC_07 (INCOMPLETE): AI chưa đưa ra assertion cần thêm `pm.expect(jsonData.user).to.not.have.property('password')`. Đã bổ sung code Chai assertion.
- TC_FR02_ST_03 (INCOMPLETE): AI không phát hiện bug của SUT: login_attempts tăng +2 mỗi lần và khóa 180s thay vì 30s. Đã ghi nhận bug này vào bug-reports/member-1.md.
- Các Test Cases còn lại (VALID): đúng các test, logic rõ ràng, đầy đủ input và expected output.

■ Phiên 2: Sinh Test Cases cho FR-07 — Gọi Hàng (GET /api/cart, POST /api/cart)

- Tên công cụ AI: Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- Ngày và giờ: 2026-08-30 21:30:15 +07:00
- Prompt của bạn: ```text Bạn là một Senior API QA Automation Engineer. Dựa trên tài liệu các tính năng EShop cho FR-07 (Gọi hàng):`
- Endpoints: GET /api/cart, POST /api/cart
- Yêu cầu Header: Authorization: Bearer
- Body khi thêm gửi: `{ "id": number, "name": string, "price": number, "quantity": number }`
- Nghiệm vụ:
 1. Người dùng thêm sản phẩm vào giỏ hàng cá nhân.
 2. Thêm cùng 1 sản phẩm nhiều lần thì tổng số lượng quantity.
 3. Phải đăng nhập mới xem/thêm được giỏ hàng.
 4. Không cho phép xem/sửa giỏ hàng của người dùng khác (chống IDOR).
 5. Validation: quantity > 0, product_id phải hợp lệ.

Hãy thiết kế 38 Test Cases bao gồm: Phân hoạch miền (12 TC), Chuyển trạng thái (10 TC), Bộ mô tả SEC-01~07 (9 TC), Schema Validation (7 TC). ``

- Yêu cầu AI:** ``markdown ### A. Phân hoạch miền & Biên (12 TCs)

- quantity: 1 (biên hợp lệ), 0 (invalid), âm (-1), số thực (1.5), số cực lớn (999999).
- id: ID tồn tại (1..5), ID không tồn tại (99999), ID âm (-1), ID kiểu chuỗi ("abc").
- price: giá khách CSDL, giá bên client-side.
- name: tên sản phẩm riêng, tên sản phẩm hợp lệ.

B. Chuyển trạng thái (10 TCs) - Giả hàng ban đầu rỗng [] -> Thêm sản phẩm A (SL 1) -> Thêm tiếp sản phẩm A (SL tăng thành 2) -> Thêm sản phẩm B -> Giả hàng có 2 items. - Test case giả như PUT /api/cart sửa SL và DELETE /api/cart/:id xóa item.

C. Bộ mô tả (9 TCs) - Request không mang Header Authorization -> 401 Unauthorized. - Request mang JWT token giả mạo / hết hạn -> 403 Forbidden. - IDOR: User A cố gắng truy cập giả hàng User B. - SQLi trong các trường payload body.

D. Schema Validation (7 TCs) - Schema Response 200 của GET /api/cart (mình các item có id, name, price, quantity). - Schema Response 200 của POST /api/cart ({"message": "Added to cart"}). - Schema Response lỗi 401/403. ``

- Ánh giá kiểm toán của con người (Human Audit Decision):**
- Nhận tổng hợp:** 24 VALID, 6 INVALID, 8 INCOMPLETE.

Chi tiết kiểm toán:

- INVALID (6 TCs): AI giả như backend có các endpoint PUT /api/cart và DELETE /api/cart theo mô tả giao diện, nhưng thực tế server.js chỉ có GET và POST. Đã chuyển các test này thành Bug Report kiến trúc.
- INCOMPLETE (8 TCs): AI không nhận ra giả hàng lưu in-memory (userCarts = {}), để lại giả hàng số bất mốt sách khi server khởi động lại. Đã bổ sung kịch bản kiểm tra tính bền vững của dữ liệu giả hàng.
- VALID (24 TCs): Các kịch bản phân hoạch quantity, kiểm tra token 401 Unauthorized, và cấu trúc Schema GET /api/cart được giả nguyên.

■ Phiên 3: Sinh Test Cases cho FR-15 — Quản Lý Sản Phẩm CRUD (POST/GET/PUT/DELETE /api/products)

- Tên công cụ AI: Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- Ngày và giờ: 2026-08-30 22:45:00 +07:00
- Prompt của bạn: ```text Bạn là một Senior API QA Automation Engineer. Dựa trên tài liệu FR-15 (Product CRUD):

• POST /api/products (Thêm mới: name, price, description, imageUrl, category_id)

• GET /api/products/:id (Xem chi tiết)

• PUT /api/products/:id (Cập nhật)

• DELETE /api/products/:id (Xóa)

• Yêu cầu quy định: Chỉ Admin mới được Thêm/Sửa/Xóa (SEC-03).

• Validation: Tên bắt buộc <= 255 ký tự; Price > 0; Category_id phải tồn tại.

Hãy thiết kế 38 Test Cases phân bổ cho 4 methods, bao gồm Domain, State Transition, Security, Schema. ```

- Yêu cầu của AI: ```markdown ### Phân bổ 38 Test Cases:

• POST /api/products (12 TCs): BVA giá (>0, =0, âm), tên SP r<=255 ký tự, category tồn tại/không tồn tại, token Admin vs User.

• PUT /api/products/:id (10 TCs): Cập nhật thông tin, cập nhật giá âm, ID không tồn tại (404), token Admin vs User.

• DELETE /api/products/:id (8 TCs): Xóa sản phẩm tồn tại, xóa ID không tồn tại, xóa lần 2, token Admin vs User.

GET /api/products/:id (8 TCs): Lấy SP ID 1, lấy SP ID không tồn tại, lấy SP ID đang chờ, Schema JSON. ```

■ Đánh giá kiểm toán của con người (Human Audit Decision):

- Nhận tổng hợp: 27 VALID, 4 INVALID, 7 INCOMPLETE.

Chi tiết kiểm toán:

- INVALID (4 TCs): AI ghi nhận backend kiểm tra authenticateToken ở POST/PUT/DELETE /api/products, nhưng server.js thì SUT hoàn toàn quên middleware authenticateToken vào các route này (Bắt k phải thêm/xóa middleware s phải). Chuyển thành Bug Bỏ m Nghiêm trọng (Critical Security Bug).
- INCOMPLETE (7 TCs): AI không phát hiện bug của SUT ở dòng 162 server.js: if (row.id % 2 === 0) row.price = row.price.toString(); (ID chẵn b ép ki u price sang string!). Đã b sung test case schema b t l i sai ki u d l i u này.
- VALID (27 TCs): Các k ch b n kiểm tra CRUD, BVA giá và tên s n ph m c gi nguyên.

Phiên 4: Chuyển i c T SUT sang Chuẩn OpenAPI 3.0

- Tên công c AI: Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- Ngày và gi: 2026-08-31 09:15:00 +07:00

Prompt của b n: text Hãy chuyển i toàn b c t API Markdown t file eshop-sut/api_specification.md thành nh d ng OpenAPI 3.0 YAML (docs/openapi.yaml) y endpoints, components schemas, parameters, securitySchemes (BearerAuth) và response status codes.

u ra của AI: T o file docs/openapi.yaml ch a toàn b 15+ API endpoints của EShop v i y components schemas (User, Product, CartItem, Order, Coupon) và securitySchemes BearerAuth.

ánh giá kiểm toán của con ng i (Human Audit Decision):

- Nhận:** VALID sau khi b sung thêm mô t l i 403 Forbidden cho các API Admin và chuẩn hóa ki u d l i u price là integer.

3. Bảng Tổng Hợp Kết Quả Kiểm Toán S Li u

Phân h API	T ng s TC AI sinh	S TC H p l (VALID)	S TC Không h p l (INVALID)	S TC Thi u sót (INCOMPLETE)	S TC ã ch nh s a
FR-02 (Ng nh p & Khóa TK)	38	31 (81.6%)	5 (13.2%)	2 (5.3%)	7
FR-07 (Gi hàng)	38	30 (78.9%)	3 (7.9%)	5 (13.2%)	8

FR-15 (Quản lý sản phẩm CRUD)	38	31 (81.6%)	5 (13.2%)	2 (5.3%)	7
TỔNG CỘNG	114	92 (80.7%)	13 (11.4%)	9 (7.9%)	22